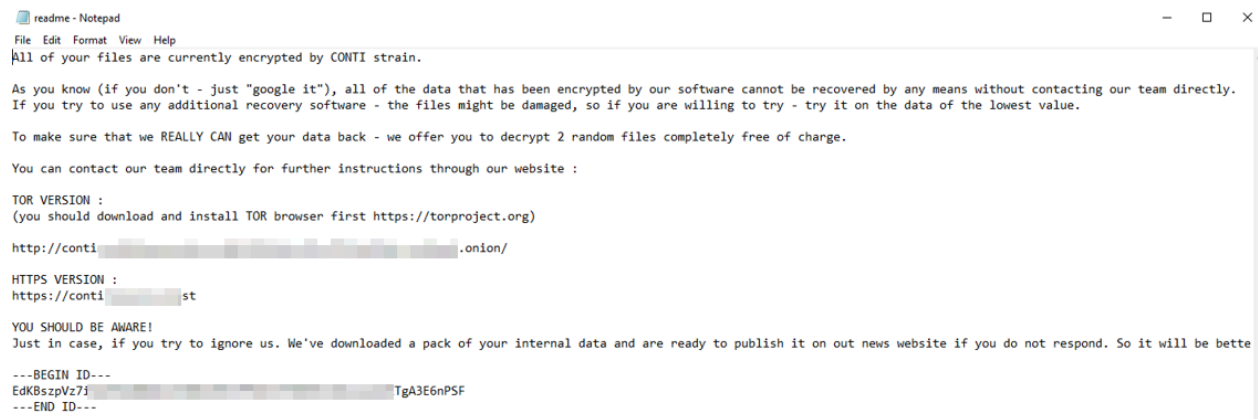


L2 - 15.5. Conti

Some employees from your company reported that they can't log into Outlook. The Exchange system admin also reported that he can't log in to the Exchange Admin Center. After initial triage, they discovered some weird readme files settled on the Exchange server. Below is a copy of the ransomware note.



```
readme - Notepad
File Edit Format View Help
All of your files are currently encrypted by CONTI strain.

As you know (if you don't - just "google it"), all of the data that has been encrypted by our software cannot be recovered by any means without contacting our team directly.
If you try to use any additional recovery software - the files might be damaged, so if you are willing to try - try it on the data of the lowest value.

To make sure that we REALLY CAN get your data back - we offer you to decrypt 2 random files completely free of charge.

You can contact our team directly for further instructions through our website :

TOR VERSION :
(you should download and install TOR browser first https://torproject.org)
http://conti[REDACTED].onion/

HTTPS VERSION :
https://conti[REDACTED].st

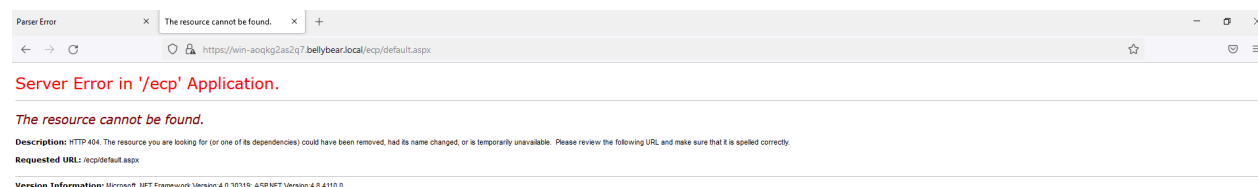
YOU SHOULD BE AWARE!
Just in case, if you try to ignore us. We've downloaded a pack of your internal data and are ready to publish it on our news website if you do not respond. So it will be better.

---BEGIN ID---
EdKbszpVz7f[REDACTED]TgA3E6nPSF
---END ID---
```

Exchange Server Compromised

Below are the error messages that the Exchange admin and employees see when they try to access anything related to Exchange or Outlook. You are assigned to investigate this situation. Use Splunk to answer the questions below regarding the Conti ransomware. Good luck!

Exchange Control Panel



```
Parser Error
The resource cannot be found.
https://win-aoqkg2as2q7.bellybear.local/ecp/default.aspx

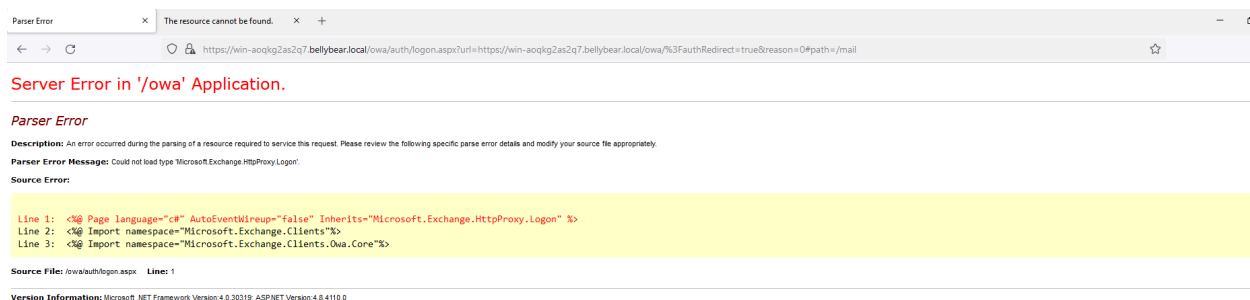
Server Error in '/ecp' Application.

The resource cannot be found.

Description: HTTP 404: The resource you are looking for (or one of its dependencies) could have been removed, had its name changed, or is temporarily unavailable. Please review the following URL, and make sure that it is spelled correctly.
Requested URL: /ecp/default.aspx

Version Information: Microsoft .NET Framework Version 4.0.30319; ASP.NET Version 4.8.4110.0
```

Outlook Web Access



`index=main sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational"`

INTERESTING FIELDS

- `a CommandLine` 100+
- `a Company` 6
- `a ComputerName` 1
- `a CurrentDirectory` 5
- `a Description` 50
- `a DestinationHostname` 3
- `a DestinationIp` 4
- `a DestinationIsIpv6` 2
- `# DestinationPort` 7
- `a DestinationPortName` 6
- `a Details` 100+
- `# EventCode` 9
- `# EventType` 2
- `a FileVersion` 15
- `a Hashes` 53
- `a Image` 78
- `a index` 1
- `a Initiated` 2
- `a IntegrityLevel` 4
- `a Keywords` 1
- `# linecount` 8
- `a LogName` 1
- `a LogonGuid` 7
- `a LogonId` 5
- `a Message` 100+

EventCode

9 Values, 100% of events

Selected

Reports

Average over time Maximum value over time Minimum value over time

Top values Top values by time Rare values

Events with this field

Avg: 8.1753003003003 **Min:** 1 **Max:** 22 **Std Dev:** 5.986062632100807

Values	Count	%
13	1,232	46.246%
3	628	23.574%
1	599	22.485%
11	104	3.904%
22	95	3.566%
5	2	0.075%
8	2	0.075%
16	1	0.038%
4	1	0.038%

1:08:54.000 PM LogName=Microsoft-Windows-Sysmon/Operational

Answer the questions below

Can you identify the location of the ransomware?

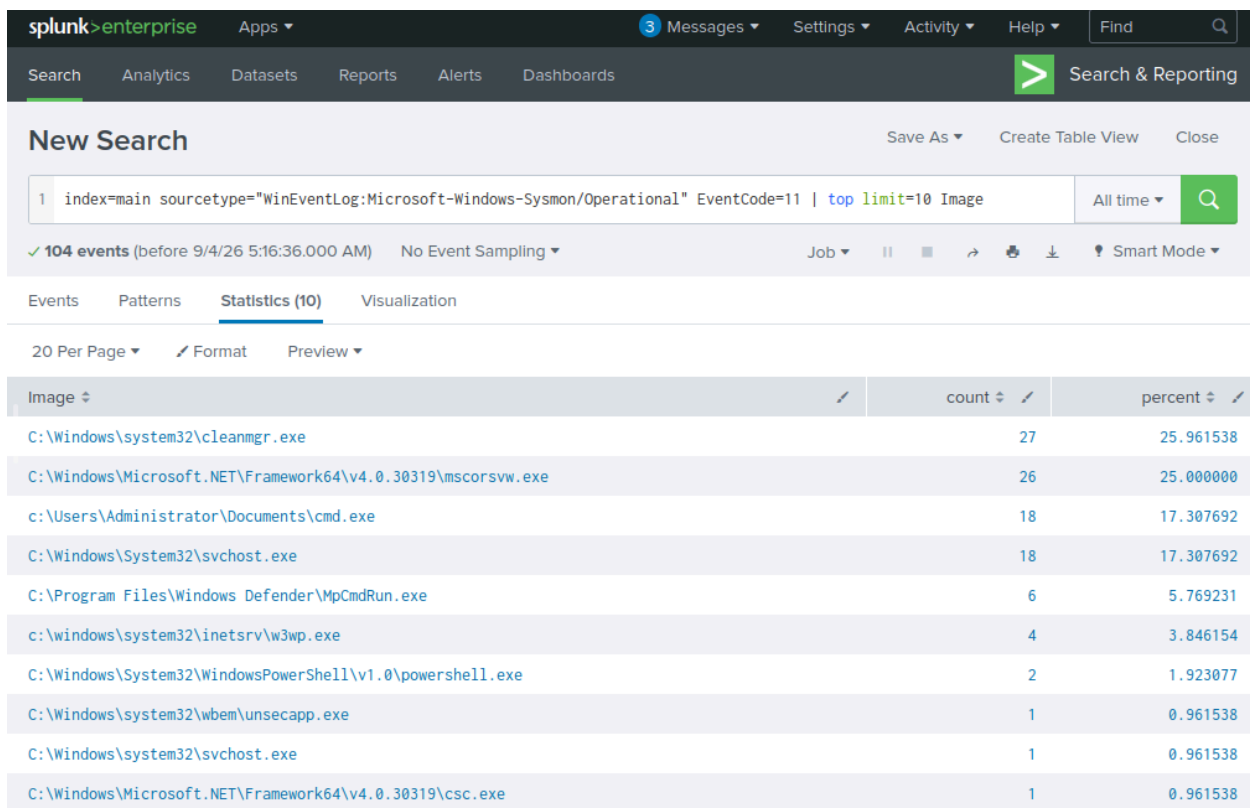
C:\Users\Administrator\Documents\cmd.exe

Since the ransomware drops `ReadMe.txt` files, we search for Event Code 11 (file creation). Reviewing the 10 process image results reveals a misplaced `cmd.exe`

binary inside `C:\Users\Administrators\Documents\cmd.exe`, which successfully answers the question.

```
index=main sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=11 | top limit=10 Image
```

This query identifies the top 10 executable processes that created files on the host, based on Sysmon Event ID 11 logs.



The screenshot shows the Splunk Enterprise web interface. At the top, there's a navigation bar with 'splunk>enterprise' and various menu items like 'Messages', 'Settings', 'Activity', and 'Help'. Below this is a 'Search & Reporting' section with a search bar containing the query: `index=main sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=11 | top limit=10 Image`. The search results show 104 events. The 'Statistics (10)' tab is selected, displaying a table with columns: 'Image', 'count', and 'percent'. The table lists the top 10 executable processes that created files, along with their counts and percentages.

Image	count	percent
C:\Windows\system32\cleanmgr.exe	27	25.961538
C:\Windows\Microsoft.NET\Framework64\v4.0.30319\mscorsvw.exe	26	25.000000
c:\Users\Administrator\Documents\cmd.exe	18	17.307692
C:\Windows\System32\svchost.exe	18	17.307692
C:\Program Files\Windows Defender\MpCmdRun.exe	6	5.769231
c:\windows\system32\inetrv\w3wp.exe	4	3.846154
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	2	1.923077
C:\Windows\system32\wbem\unsecapp.exe	1	0.961538
C:\Windows\system32\svchost.exe	1	0.961538
C:\Windows\Microsoft.NET\Framework64\v4.0.30319\csc.exe	1	0.961538

What is the Sysmon event ID for the related file creation event?

11

File creation activity is logged under Sysmon Event Code 11.

Can you find the MD5 hash of the ransomware?

290c7dfb01e50cea9e19da81a781af2c

By filtering for the specific executable path from question 1 along with the MD5 field, the hash `290c7dfb01e50cea9e19da81a781af2c` was extracted. Submitting this MD5 string to VirusTotal produced over 60 malicious alerts, confirming the file is harmful and providing the correct answer.

```
index=main Image="C:\\Users\\Administrator\\Documents\\cmd.exe" MD5
```

This query searches for events involving `cmd.exe` executed from the Administrator's Documents directory and displays or filters by its MD5 hash.

The screenshot shows the Splunk Enterprise search interface. The search bar contains the query: `index=main Image="C:\\Users\\Administrator\\Documents\\cmd.exe" MD5`. The search results show a single event with details including the MD5 hash `290c7dfb01e50cea9e19da81a781af2c`. The event details include the following information:

- Time: 09/08/2021 04:05:32 PM
- TerminalSessionId: 0
- IntegrityLevel: System
- Hashes: MD5=290c7dfb01e50cea9e19da81a781af2c, SHA256=53b1c1b2f41a7fc300e97d036e57539453ff82001dd3f6abf07f4896b1f9ca22, IMPHASH=23f815785db238377f4513be54dba574
- ParentProcessGuid: {72893ba8-1628-6139-7c02-000000000c00}
- host = WIN-AOQKG2AS2Q7
- source = WinEventLog:Microsoft-Windows-Sysmon/Operational
- sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational

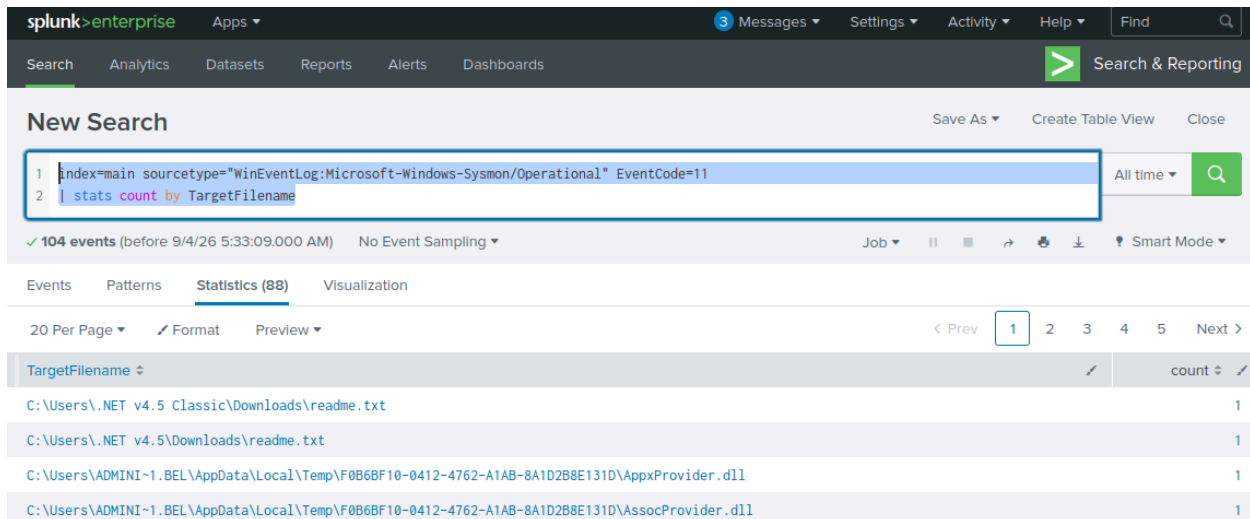
What file was saved to multiple folder locations?

readme.txt

Querying Sysmon Event Code 11 logs isolates the ransomware's drop locations by revealing widespread `readme.txt` creation within the `TargetFileName` field.

```
index=main sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=11  
| stats count by TargetFileName
```

This query lists all file creation events (Sysmon Event Code 11) grouped by the created file path (`TargetFilename`), displaying the total count of times each file was created.



The screenshot shows the Splunk Enterprise interface. The search bar contains the query:

```
1 index=main sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=11
2 | stats count by TargetFilename
```

The search results show 104 events. The results table is displayed in Statistics view, showing the following data:

TargetFilename	count
C:\Users\.NET v4.5 Classic\Downloads\readme.txt	1
C:\Users\.NET v4.5\Downloads\readme.txt	1
C:\Users\ADMINI~1.BEL\AppData\Local\Temp\F0B6BF10-0412-4762-A1AB-8A1D2B8E131D\AppxProvider.dll	1
C:\Users\ADMINI~1.BEL\AppData\Local\Temp\F0B6BF10-0412-4762-A1AB-8A1D2B8E131D\AssocProvider.dll	1

What was the command the attacker used to add a new user to the compromised system?

`net user /add securityninja hardToHack123$`

Searching Splunk for `net user` executions exposes the exact command used by the attacker in the `CommandLine` field.

```
index=main sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational" CommandLine="/add"
```

This query searches for Sysmon process creation logs where the command line execution contains the `/add` flag, typically used to detect user account creation attempts.

```

a Keywords 1
# Linecount 1
a LogName 1
a LogonGuid 1
a LogonId 1
a Message 6
a OpCode 1
a OriginalFileName 2
a ParentCommandLine 4
a ParentImage 2
a ParentProcessGuid 4
# ParentProcessId 4
a ProcessGuid 6
# ProcessId 6
a Product 1
a punct 1
# RecordNumber 6

```

ParentCommandLine

4 Values, 100% of events

Selected

Reports

Top values Top values by time Rare values

Events with this field

Values	Count	%
C:\Windows\system32\cmd.exe	3	50%
net localgroup "Remote Desktop Users" "securityninja" /add	1	16.667%
net localgroup administrators securityninja /add	1	16.667%
net user /add securityninja hardToHack123\$	1	16.667%

The attacker migrated the process for better persistence. What is the migration target (full image path)?

C:\Windows\System32\wbem\unsecapp.exe

Following a hint to search for Sysmon Event Code 8 (CreateRemoteThread), the query yielded two log entries. Reviewing the `SourceImage` and `TargetImage` fields revealed `C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe` injecting into `C:\Windows\System32\wbem\unsecapp.exe`.

```

index=main sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=8
| table SourceImage, TargetImage

```

This query identifies remote thread injection attempts (Sysmon Event ID 8) by displaying a table of the source process (`SourceImage`) injecting code into the target process (`TargetImage`).

The screenshot shows the Splunk Enterprise interface. At the top, there's a navigation bar with 'splunk>enterprise' and various menu items like 'Messages', 'Settings', 'Activity', and 'Help'. Below this is a secondary navigation bar with 'Search', 'Analytics', 'Datasets', 'Reports', 'Alerts', and 'Dashboards'. The main content area is titled 'New Search' and contains a search bar with the following query:

```
1 index=main sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=8
2 | table SourceImage, TargetImage
```

Below the search bar, it indicates '2 events (before 9/4/26 5:49:30.000 AM)' and 'No Event Sampling'. The results are displayed in a table with two columns: 'SourceImage' and 'TargetImage'.

SourceImage	TargetImage
C:\Windows\System32\wbem\unsecapp.exe	C:\Windows\System32\lsass.exe
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	C:\Windows\System32\wbem\unsecapp.exe

The attacker also injected into a system process to retrieve the hashes. What is the target process image used for getting the system hashes?

C:\Windows\System32\lsass.exe

Logs indicate `unsecapp.exe` migrated into `lsass.exe`, a critical Windows process responsible for system authentication, authorization, and credential hash management.

What is the web shell the exploit deployed to the system?

i3gfPctK1c2x.aspx

Searching web logs for `.aspx` extensions highlighted the `cs_uri_stem` field, which displayed a highly suspicious script path that served as the answer.

```
index=main sourcetype=iis cs_method=POST
| search .php OR .asp OR .aspx OR .jsp
```

This query searches IIS web server logs for POST requests aimed at dynamic script endpoints (`.php`, `.asp`, `.aspx`, or `.jsp`), which is often used to detect web shell activity or file upload attempts.

1 index=main sourcetype=iis cs_method=POST
2 | search *.php* OR *.asp* OR *.aspx* OR *.jsp*

✓ 187 events (before 9/4/26 5:51:48.000 AM) No Event Sampling ▾ Job ▾ || ■

Events (187) Patterns Statistics Visualization

Format Timeline ▾ List ▾ ↗ Format 20 Per Page ▾ < Prev 1 2 3 4

< Hide Fields ≡ All Fields

SELECTED FIELDS
a host 1
a source 4
a sourcetype 1

INTERESTING FIELDS
a ActivityCorrelationID 100+
a c_ip 2
a cafeReqId 100+
a CorrelationID 1
a cs_method 1
a cs_Referer 13
a cs_uri_query 100+
a cs_uri_stem 6
a cs_User_Agent 2
a cs_username 2
a date 4
date_hour 5
date_mday 4
date_minute 56

i	Time	Event
>	9/8/21 1:07:45.000 PM	2021-09-08 20:07:45 fe80::50c7:e3a5:fed7:dc19%5 POST /ecp/DDI elationID=34a08616-c3ab-0094-fd76-cc3f52f82808&workflow=GetCo

cs_uri_stem [X]

6 Values, 100% of events Selected Yes No

Reports
Top values Top values by time Rare values
Events with this field

Values	Count	%
/ecp/DDI/DDIService.svc/GetList	171	91.444%
/owa/auth.owa	8	4.278%
/owa/auth/i3gfPctK1c2x.aspx	4	2.139%
/ecp/DDI/DDIService.svc/NewObject	2	1.07%
/ecp/DDI/DDIService.svc/GetObject	1	0.535%
/owa/lang.owa	1	0.535%

What is the command line that executed this web shell?

attrib.exe -r \\win-aoqkg2as2q7.bellybear.local\C\$\Program
Files\Microsoft\Exchange
Server\V15\FrontEnd\HttpProxy\owa\auth\i3gfPctK1c2x.aspx

Filtering the **CommandLine** field for references to the malicious web shell returned a single process execution log containing the required answer.

```
index=main i3gfPctK1c2x.aspx sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational"
```

This query searches Sysmon operational logs for any events associated with the specific ASPX file **i3gfPctK1c2x.aspx**, likely used to investigate potential web shell or malicious file activity.

New SearchSave

1 index=main i3gfPctK1c2x.aspx sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational"

✓ 1 event (before 9/4/26 5:53:52.000 AM) No Event Sampling ▾

Job ▾ || ■

Events (1) Patterns Statistics Visualization

Format Timeline ▾

List ▾ / Format

20 Per Page ▾

< Hide Fields

≡ All Fields

SELECTED FIELDS

a host 1

a source 1

a sourcetype 1

INTERESTING FIELDS

a CommandLine 1

a Company 1

a ComputerName 1

a CurrentDirectory 1

a Description 1

EventCode 1

EventType 1

a FileVersion 1

i Time Event

CommandLine

1 Value, 100% of events

Selected

Yes No

Reports

Top values

Top values by time

Rare values

Events with this field

Values

Count

%

attrib.exe -r \\win-aoqkg2as2q7.bellybear.local\C\$\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\i3gfPctK1c2x.aspx

1

100%

What three CVEs did this exploit leverage? Provide the answer in ascending order.

CVE-2020-0796,CVE-2018-13374,CVE-2018-13379

Open-source research into Conti ransomware tactics, techniques, and procedures (TTPs) revealed a catalog of specific CVEs regularly leveraged in their campaigns.

L2 - 15.5. Conti

9